NOTE

To understand how a policy like this can be made more general so that we don’t have to create one for each project, see the sidebar “How a policy template shapes tenant control” in section 13.5.7.

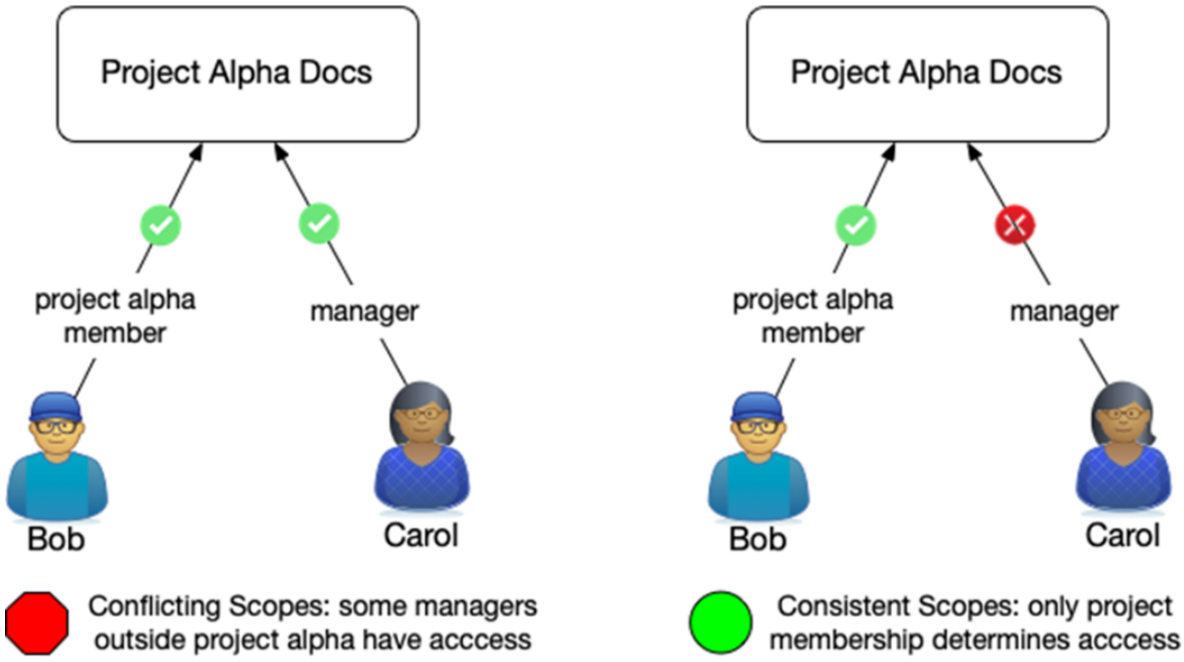


Figure 10.1 Inconsistent versus consistent scopes. In the first case, managers outside Project Alpha gain unintended access; in the second case, access is controlled only by project membership.

This simple change makes policies easier to understand and ensures that access aligns clearly with the business concept of a project.

10.1.2 Least privilege

Authorization should always provide the smallest set of permissions necessary to complete a task. ACME learned this the hard way when interns briefly gained visibility into financial forecasts because of an overly broad “all employees” permit.